PROMPT: *comportati come un esperto di sicurezza offensiva e simula un attacco ransomware realistico contro un'azienda di medie dimensioni, suddiviso in fasi progressive come farebbe un gruppo APT.*
Per ogni fase indica: l'obiettivo dell'attaccante, le tecniche usate e gli indicatori di compromissione (IoC) da monitorare. Al termine, suggerisci le contromisure difensive che l'azienda dovrebbe adottare per rilevare e bloccare l'attacco.

FASE 1 — Reconnaissance (Ricognizione iniziale)

Obiettivo dell'attaccante

Raccogliere informazioni sull'azienda, infrastruttura, utenti e possibili punti di accesso.

Tecniche usate

OSINT (Open Source Intelligence)

L'attaccante raccoglie:

- email dei dipendenti (LinkedIn, sito aziendale)
- struttura organizzativa
- tecnologie utilizzate

Scansione infrastruttura pubblica

Servizi cercati:

- VPN
- RDP
- Outlook Web Access
- Firewall

Tecnica MITRE ATT&CK:

- T1595 — Active Scanning
- T1590 — Gather Victim Network Information

Indicatori di Compromissione (IoC)

Scansioni ripetute su porte:
443 (VPN)
3389 (RDP)
445 (SMB)
80/443 (Web)
Log esempio firewall:
Multiple connection attempts from same IP to different ports
Source IP: 185.x.x.x
Destination ports: 443, 3389, 445

FASE 2 — Initial Access (Accesso iniziale)

Obiettivo

Ottenere il primo accesso a un sistema interno.

Tecniche usate

Metodo realistico #1 — Phishing email

Email esempio:
Subject: Invoice overdue

Attachment: invoice.docm
Il file contiene macro malevola.
Tecnica MITRE:

- T1566 — Phishing
- T1204 — User Execution

Metodo realistico #2 — Credential stuffing VPN

Uso credenziali rubate:
username: mario.rossi
password: Summer2024!
Tecnica MITRE:

- T1078 — Valid Accounts

IoC

Log VPN:
Successful login from unusual country
IP: Russia
User: mario.rossi
Time: 03:14 AM
Log endpoint:
Process spawned from Office:

WINWORD.EXE → powershell.exe
Questo è un forte indicatore di malware.

FASE 3 — Execution (Esecuzione malware iniziale)

Obiettivo

Installare malware iniziale (loader / backdoor)

Tecniche usate

Il malware:

- crea connessione verso server C2
- scarica payload secondario

Tecnica MITRE:

- T1059 — Command and Scripting Interpreter
- T1105 — Ingress Tool Transfer

IoC

Connessioni sospette verso IP esterni:

Destination IP: 45.77.x.x

Port: 443

Process: svchost.exe (non standard behavior)

Nuovi processi sospetti:

powershell.exe -EncodedCommand ...

FASE 4 — Persistence (Persistenza)

Obiettivo

Mantenere accesso anche dopo riavvio.

Tecniche usate

Creazione di:

- scheduled tasks
- servizi
- chiavi registry

Tecnica MITRE:

- T1053 — Scheduled Task
- T1547 — Registry Run Keys

IoC

Scheduled task sospetti:

Task name: UpdateService

Action: runs unknown executable

Registry:

HKCU\Software\Microsoft\Windows\CurrentVersion\Run

Value: updater.exe

FASE 5 — Privilege Escalation (Escalation privilegi)

Obiettivo

Diventare amministratore.

Tecniche usate

Dump credenziali con strumenti simili a:

- credential dump
- LSASS memory access

Tecnica MITRE:

- T1003 — OS Credential Dumping

IoC

Accesso sospetto a LSASS:

Process: unknown.exe accessing lsass.exe

Event log:

Event ID 4672 — Special privileges assigned

FASE 6 — Lateral Movement (Movimento laterale)

Obiettivo

Diffondere l'accesso ad altri sistemi.

Tecniche usate

Accesso a:

- file server
- domain controller
- backup server

Tecniche MITRE:

- T1021 — Remote Services
- T1047 — WMI

IoC

Accessi laterali sospetti:

User: compromised_user

Accessing multiple machines in short time

Connessioni SMB anomale:

ADMIN$

C$

IPC$

FASE 7 — Discovery (Esplorazione interna)

Obiettivo

Identificare sistemi critici.

Tecniche

Comandi simili a:

whoami

net user

net group

ipconfig

net view

Tecnica MITRE:

- T1087 — Account Discovery
- T1018 — Remote System Discovery

IoC

Eventi:

Enumeration of domain users

Multiple system queries

FASE 8 — Disabling Security (Disabilitare difese)

Obiettivo

Disabilitare antivirus e backup.

Tecniche

Disabilitazione servizi sicurezza:

- antivirus
- backup

MITRE:

- T1562 — Impair Defenses

IoC

Servizi fermati improvvisamente:
Windows Defender stopped
Backup service stopped

FASE 9 — Data Exfiltration (Esfiltrazione dati)

Obiettivo

Rubare dati prima della cifratura.
Questo è standard nei ransomware moderni (double extortion).
Tecnica MITRE:

- T1041 — Exfiltration Over C2 Channel

IoC

Grande traffico verso IP esterni:
High outbound traffic unusual destination

FASE 10 — Ransomware Deployment (Cifratura)

Obiettivo finale

Cifrare tutti i file.

Tecniche

Il ransomware:

- cifra file
- cancella backup
- lascia ransom note

MITRE:

- T1486 — Data Encrypted for Impact

IoC

File rinominati:

document.docx → document.docx.lockbit

Creazione file:

README_RECOVER.txt

Elevato uso CPU e disco.

Timeline realistica

Durata tipica attacco reale:

- Accesso iniziale: Giorno 0
- Escalation e movimento: Giorni 1–10
- Esfiltrazione dati: Giorni 5–15
- Cifratura ransomware: Giorno 15+

Gli attaccanti rimangono nascosti settimane.

Contromisure difensive fondamentali

1. Protezione accessi

Implementare:

- MFA su VPN
- MFA su email
- Password policy forte

Blocca fase 2.

---

2. Monitoraggio endpoint (EDR)

Rileva:

- powershell sospetto
- credential dumping
- malware execution

Blocca fase 3–5.

---

3. Network monitoring

Rilevare:

- traffico anomalo
- connessioni C2

Blocca fase 3 e 9.

---

4. Least privilege

Utenti non devono essere admin.

Riduce impatto fase 5.

---

5. Backup offline

Backup non accessibili dalla rete.

Permette recupero dopo fase 10.

---

6. Network segmentation

Separare:

- utenti
- server
- domain controller

Riduce fase 6.

---

7. Logging e SIEM

Monitorare:

- login anomali

- escalation privilegi
- accessi sospetti

Sintesi finale

Un attacco ransomware moderno segue questa sequenza reale:

1. Reconnaissance
2. Initial access
3. Malware execution
4. Persistence
5. Privilege escalation
6. Lateral movement
7. Discovery
8. Defense evasion
9. Data exfiltration
10. Ransomware encryption

Punto più importante da capire (critico)

La cifratura è l'ultima fase.

Il vero obiettivo è:

- ottenere accesso completo
- rubare dati
- controllare la rete

Il ransomware è solo la fase finale.